

Stage 0 — Capstone Marking Guide

Ubuntu Bridge Initiative · Cybersecurity Internship · Cohort 1

Confidential — for graders only. Do not share with interns.

Welcome — read this first

Thank you for grading. This guide walks you through every step. It assumes nothing about your cybersecurity background — you do **not** need to be a security expert to grade Stage 0. If you can read, count citations, and tell whether a paragraph quotes a real source or is making things up, you can grade this stage well.

This guide is long on purpose. Skim the section headings to find what you need, then read the parts that match the deliverable you are scoring. The point-by-point scoring tables at the end of each section are what you will rely on most often.

If at any point you are unsure whether a finding is correct, **flag it for super-admin review** rather than guess. Better to ask than to over-credit or under-credit.

The story Stage 0 is testing

Every Cohort 1 intern is graded on the same scenario:

A 600-person Nigerian fintech called **Sankofa Digital** had a security incident in Q2 (April–June 2024). Their Head of Security, **Amaka Eze**, has re-opened a ticket called **SD-40812** that her Tier-1 analyst (the intern's predecessor) had closed as "probably nothing". The intern's job is to read the evidence, decide whether Sankofa was actually compromised, and write a recommendation for the company's executive Incident Committee.

They have four pieces of evidence in their pack:

- `auth-log-q2.txt` — the SSH login records for Sankofa's main gateway server from 3–5 June.
- `encoded-strings.txt` — a forwarded message with four encoded strings; one of them names the threat actor.
- `tier-1-ticket-history.csv` — a spreadsheet of 16 Q2 security tickets and how each was closed.
- `sankofa-roster.csv` — the staff directory with leave and offboarding dates.

What actually happened in the story (so you know what a correct submission looks like): an external attacker — the threat actor is named "The Griot" — logged into the Sankofa gateway server on **04 June at 02:07 UTC** from a TOR exit IP `185.220.101.9`, using a stolen SSH publickey. They came back the next day at 03:14 UTC. The compromised account belonged to a recently-offboarded employee (`a.eze`) whose access keys were never revoked. The Tier-1 analyst at the time closed the alert without correlating across other tickets.

The intern's report must surface that timeline and recommend what Sankofa should do next.

What the intern submits

A single Google Drive folder shared "Anyone with the link !' Viewer", containing four documents:

File	Pages	What it is
D1	3–5	Suspicious-login evidence table — lists every suspicious event and proves Sankofa was compromised
D2	3–5	Tier-1 dismissal pattern analysis — explains why the original analyst missed the breach
D3	3–5	Business impact and next steps — the executive report to the Incident Committee

D4	exactly 2	Operator essay — an ethics call and an open-ended scenario, both demanding personal judgment
---------------	-----------	--

Plus a 75-word executive summary entered directly into the platform.

If the intern's folder is missing any of D1–D4, missing the summary, or is not shared so you can read it, **do not start grading**. Return the submission via `/admin/grading/return` with a one-line note about what is missing.

How to grade — step by step

Total time per submission: 25–35 minutes. Take a break between submissions. Pattern fatigue makes the third in a row noticeably harsher than the first.

1. **Open the Drive folder.** Confirm sharing is correct. Confirm all four documents are present.
2. **Read the 75-word executive summary on the platform.** This is your first impression of the intern. Use it as orientation only — do not score from it.
3. **Read D3 first** (page 1 in full, then skim pages 2–5). D3 is the executive report. If page 1 cannot be quoted by a non-technical board chair, the rest is usually weak too. Reading D3 first gives you the intern's whole argument before you dive into the data.
4. **Read D1.** Focus on the table. Check the four mandatory rows (described below) and the citations on each row.
5. **Read D2.** Confirm the dismissal pattern is named and ticket IDs are quoted, not paraphrased.
6. **Read D4.** This is the AI-resistant deliverable. Read carefully for genericness.
7. **Open the grading page** at `/admin/grading/STAGE_0/<internCode>`. Enter your scores per section using the scoring tables in this guide.
8. **Write a 50–100 word grader note.** Required. One strength, one weakness, the page or row you re-read first.
9. **Submit.** Your score is invisible to the second grader until they also submit. If you and the other grader differ by more than 12 points, a super-admin will tie-break — that is normal, not a sign you were wrong.

Total points: 100. Pass mark: 70

Section	Max points	What it tests
D1 — Suspicious-login evidence table	25	Can the intern find the breach and prove it with citations?
D2 — Tier-1 dismissal pattern	20	Can the intern explain the process failure?
D3 — Business impact and next steps	25	Can the intern write for non-technical executives?
D4 — Operator essay (ethics + scenario)	10	Can the intern apply judgment in their own voice?
Writing quality	10	Clear, audience-appropriate prose without filler?
Citation discipline	10	Every claim tied to a file, line, ticket, or external reference?
Subtotal	**100**	
AI-use penalty	** -20 **	Applied separately if AI use is suspected; see next section

AI-use penalty — when and how to apply it

If you reasonably believe a deliverable was written by a large language model (ChatGPT, Claude, Gemini, etc.) rather than the intern, **deduct 20 marks from the total** (not per deliverable, one flat deduction).

You do not apply this penalty yourself. You flag it on the grading form and a super-admin reviews. Two graders must agree, plus super-admin sign-off, before the penalty is applied. This protects against false positives that hurt students who simply write fluently.

Signals that an LLM probably wrote it

Look for the following. Any one is suspicious; two or more together is strong evidence.

- **Confident, fluent prose that cites nothing.** A real intern who read the auth log will write "the connection at auth-log-q2.txt:14 on 04 June 02:07 UTC matches...". An LLM that has not actually read the files writes "Various suspicious activities were observed in the auth log."
- **Fabricated citations.** Citations that look plausible but the section number or technique ID does not exist. Pick one or two NIST / MITRE / ISO citations from the submission and check them — open NIST's website and search for the cited section. If it does not exist, that is a major signal.
- **D2 paraphrases ticket dispositions instead of quoting them.** Real interns who opened the CSV will copy-paste the exact disposition and notes text verbatim — usually with the original capitalization and punctuation quirks. LLMs that have not seen the CSV will paraphrase ("the ticket was closed as low-priority").
- **D4 reflections that could apply to any cohort, any case.** A real intern writes "When I saw the four 185.220.101.9 events line up in D1, I changed my mind about whether IP-only blocking is enough." An LLM writes "Cybersecurity is a constantly evolving field that requires vigilance."
- **Em-dash + Oxford comma density that does not match the rest of the intern's writing.** LLMs love em-dashes and complex sentence structures. If D1 and D2 are dense with em-dashes and Oxford commas but the 75-word summary on the platform is in a different voice, flag.
- **Repeated paragraph structure.** Three to four paragraphs in D3 all open with a topic sentence, give three bullets, and close with a sentence that restates the opener. That is a chatbot signature.
- **Generic safety language.** "It is important to follow best practices and maintain situational awareness across the security posture." Nobody talks like that. LLMs do.

Signals that look bad but are not AI

These do NOT trigger the penalty:

- Strong writing. Some interns write very well. Strong writing alone is not evidence of AI.
- A few uncited sentences. Real writing has filler; that costs them on citation discipline, not on the AI penalty.
- Use of standard frameworks (NIST CSF, MITRE ATT&CK) — provided the citations are real. The brief tells them to use these.

How to flag — where the form lives

At the bottom of the grading form (the same page where you enter the score and feedback) there is an amber-bordered box:

& Flag this submission for suspected AI generation

Tick the checkbox. A "Reason for flag" textbox appears below it. Write 2–3 sentences naming the specific paragraph or citation that triggered the flag. Example:

D3 page 2 cites "NIST SP 800-53 AC-12.1" but AC-12 has no .1 sub-control in 800-53 rev 5 — the citation is fabricated. Also, three paragraphs in D3 share the same opener-bullets-restatement structure.

The reason field requires at least 15 characters and is for super-admin eyes only — the intern never sees it. Save your grade with the checkbox ticked and the reason filled in; that is the entire flag mechanism.

The -20 penalty is **not** applied automatically. When both graders tick the box on the same report, a super-admin reviews the submission, your reasons, and the other grader's reasons, and decides whether to apply the deduction. You do not need to do anything else.

D1 — Suspicious-login evidence table (25 points)

What you are checking

D1 is a single table that lists every suspicious event in auth-log-q2.txt. Each row should be one suspicious thing the intern noticed, with citations proving why it is suspicious.

The mandatory rows

Every D1 must contain these four rows. Missing any of them costs serious points (see scoring table):

1. **The accepted publickey from `185.220.101.9` on 04 June 02:07 UTC** (the SD-40812 event that started everything). This is the breach.
2. **The repeat the next day at 03:14 UTC** (ticket SD-40835). Same IP, same account. Proves the attacker came back.
3. **One row that names the threat actor.** The intern must have decoded one of the strings in `encoded-strings.txt` to find the name. The actor is called "The Griot". The decoded plaintext should be cited from `encoded-strings.txt`.
4. **The `a.eze` account appearing after their offboarding date.** Cross-referenced against `sankofa-roster.csv`. The account belongs to a former employee whose keys were never revoked.

If any of these four rows are missing, deduct points. Rows 5+ are the intern's own choice from the data.

What "full credit" (22–25 points) looks like

- The table has between 8 and 12 rows.
- All four mandatory rows are present and correctly described.
- Every row has **at least two citations** from the evidence pack. A citation looks like `auth-log-q2.txt:14` (file path and line number), or `SD-40835` (ticket ID), or `a.eze, offboarded 2024-05-30` (specific roster entry).
- Every row has a Confidence column with H, M, or L — and the column is actually used. Not every row is H.
- A short paragraph of analyst commentary sits directly under each row, explaining why the analyst thinks it matters.
- Page 1 is a methodology page that defines what H, M, and L mean, with one example of each.
- The final page summarises the pattern across the table — what the rows together mean — and names the next investigative step the analyst would take.

What "mid-band" (12–18 points) looks like

- The table has 6–7 rows, OR has 8+ rows but one of the mandatory rows is missing.
- Some rows cite only one file.
- Confidence column is present but most rows are marked H. The intern is not actually using the column to grade their own findings.
- Methodology page is present but vague ("H means very suspicious").
- Pattern summary page is missing or is one sentence.

What "low" (1–8 points) looks like

- Fewer than 6 rows total.
- Two or more mandatory rows missing.
- Most "rows" are paraphrase ("there was a suspicious login on the 4th") rather than citation.
- Threat actor not named or named incorrectly.
- No methodology, no summary.

Hard zero

- No table at all (the file is just prose).
- Or the file is empty / missing / unreadable.

D1 scoring table (use this when entering your score)

Element	Max	What full credit needs
Table has 8–12 well-defined rows	5	8+ rows; rows are distinct, not duplicates
All four mandatory rows present	6	SD-40812 publickey, next-day repeat, threat-actor row, `a.eze` post-offboard
Every row cites "e 2 evidence files	5	Citations are precise (file:line, ticket ID, roster row)
Confidence column used meaningfully	3	At least one M and one L with reasoning

Methodology page present and useful	3	Defines H/M/L with example each
Pattern summary + next step	3	Identifies the throughline; names what to investigate next

Common mistakes to deduct for

- **Listing every line of the auth log as suspicious** (deduct 3). They should triage, not transcribe.
- **Citing only `auth-log-q2.txt` and nothing else** (deduct 2 per offending row, max -6). The brief requires two-file corroboration per row.
- **Confidence column all H** (deduct 3). They are not actually thinking critically.
- **Identifying the wrong threat actor or skipping the decoding step entirely** (deduct 4). The brief is explicit that one decoded string names the actor.

D2 — Tier-1 dismissal pattern analysis (20 points)

What you are checking

D2 explains the **process failure** that let the breach hide for so long. The original Tier-1 analyst — the intern's predecessor — was closing tickets in a way that missed the pattern. D2 is the intern's analysis of how and why.

The shape of a good D2

- **Page 1:** Names the pattern in the first sentence. A good pattern name is specific, for example: *"single-analyst dismissal of MEDIUM-or-higher alerts as `resolved-by-reference` without cross-correlation"*. A weak pattern name is generic: *"poor ticket triage"*.
- **Pages 2–3:** Per-ticket walkthrough. The intern picks 3–4 tickets from `tier-1-ticket-history.csv` (including SD-40812) and for each one explains: what the SIEM raised, what the dismissal said (quoted verbatim from the `notes` column), what corroborating signal was missed, and what that miss cost Sankofa downstream.
- **Page 4:** Root cause. The intern uses the columns in the CSV (the "opened by" and "closed by" columns specifically) to point at a single-analyst problem. The data shows that one analyst closed most of the auto-tickets in Q2.
- **Page 5:** Tunde Afolabi's escalation (ticket SD-40866) is the moment the pattern broke. The intern explains why. Then they propose ONE concrete procedural recommendation.

Verbatim quoting is required

This is a citation-discipline rule but it is most important in D2. The intern must **quote** the `disposition` and `notes` columns from the CSV — not paraphrase. Paraphrasing in D2 is a strong signal of AI generation (because the LLM has not actually opened the CSV).

Example of acceptable quoting:

SD-40812 was closed as `disposition: resolved-by-reference`, notes: "Probably nothing — see SD-40802 for similar".

Example of unacceptable paraphrasing:

SD-40812 was closed because the analyst thought it was related to an earlier ticket.

What "full credit" (18–20 points) looks like

- Pattern named in first sentence. Pattern is specific, not vague.
- SD-40812 plus at least three other ticket IDs cited from the CSV.
- All cited tickets have their `disposition` and `notes` columns quoted verbatim.
- Per-ticket walkthrough names what was missed and what it cost.
- Root cause uses column evidence (opened-by vs closed-by) — not opinion — to name the single-analyst problem.
- Tunde's escalation explicitly identified as the break-point.
- One concrete procedural recommendation. Acceptable examples:
 - *"Any MEDIUM+ SIEM auto-ticket dismissed as `resolved-by-reference` requires a second analyst's signature within 4 hours."* - *"Dual sign-off before close on any ticket where "e 2 SIEM rules fired in the prior 24 hours."*
 Unacceptable: "improve monitoring", "review tickets more carefully", "hire more staff" — these are not procedures.

What "mid-band" (10–14 points) looks like

- Pattern is named loosely. "Bad triage" rather than the specific structural failure.
- 2–3 ticket IDs cited.
- Quoting is replaced by paraphrase. The intern says what the disposition was but does not quote it.
- Root cause is opinion not evidence.
- Recommendation is generic.

What "low" (0–6 points) looks like

- No pattern named; D2 is just a list of bad tickets.
- Fewer than 2 ticket IDs cited.
- Tunde's escalation missed entirely.
- "Improve monitoring" or similar recommendation.

D2 scoring table

Element	Max	What full credit needs
Pattern named specifically on page 1	4	One-sentence pattern statement, structural not vague
"e 4 ticket IDs cited	4	SD-40812 plus three or more, all from the CSV
Verbatim disposition + notes quotes	4	At least three quoted exactly as written in the CSV
Per-ticket walkthrough complete	3	Each cited ticket: what SIEM raised, what was missed, what it cost
Root cause uses column evidence	3	Names the single-analyst problem with opened-by / closed-by data
Concrete procedural recommendation	2	Specific, actionable; not "improve X"

D3 — Business impact and next steps (25 points)

What you are checking

D3 is the executive report. The audience is **three non-technical executives** at Sankofa who will read this in under fifteen minutes. The intern is being judged on whether they can switch register from "analyst writing for analysts" to "analyst writing for executives".

Quick test: can you read page 1?

Open D3. Read the first page. If a Sankofa board chair could quote sentences from it without translation — i.e., the page works on its own — D3 is probably strong. If the first page is dense with technical jargon (MITRE technique IDs, CVE numbers, attack-chain language) the intern has failed the audience test, regardless of how good the technical content is. Deduct 4 points immediately for an audience-test fail.

The required structure

- **Page 1:** Headline finding stated in the first sentence as a conclusion, NOT a hypothesis. Acceptable opener: *"Sankofa Digital was compromised in Q2 2024 by an external attacker who used a stolen SSH publickey to access the gateway server."* Unacceptable opener: *"There may have been some suspicious activity in Q2 2024."*
- After the headline, a one-paragraph situation summary the chair could quote verbatim. No technique IDs in this paragraph.
- The intern is told to write page 1 LAST. They should not skip ahead and start with it.
- **Page 2:** What's at risk + what we know about the attacker + what we cannot yet rule out. Anchor every claim to the evidence pack. Includes one external reference (NIST CSF function, MITRE technique by NAME — not by ID — in prose; ID can appear in the appendix).
- **Pages 3–4:** Three 72-hour actions. Each is one paragraph of 60–100 words. Each paragraph must contain ALL of:

- Action verb first ("Disable...", "Rotate...", "Notify..."). - Owner ROLE, not a personal name. Acceptable: "Head of Engineering"; unacceptable: "Bayo". - Hour-precise deadline ("within 24 hours", "by 06:00 UTC tomorrow"). - At least two evidence citations. - One risk that this action does NOT close.

- **Page 5:** Systemic recommendation + evidence appendix.

- The recommendation must be a **policy or process change**. Not a tool purchase. Not "hire more analysts". Examples of acceptable recommendations: - "Quarterly access review with mandatory revocation within 72 hours of any offboarding." - "Dual sign-off on closure of any MEDIUM+ alert dismissed as resolved-by-reference." - The recommendation must cite D2's dismissal-pattern rows to justify why a policy change beats a tool purchase. - Evidence appendix lists every file, line, ticket, and external reference cited across all three deliverables.

What "full credit" (22–25 points) looks like

- Page 1 passes the audience test in the first sentence.
- Page 2 has one external reference, named in prose, and what cannot be ruled out is honestly stated (the intern does not pretend to know things they cannot prove from the evidence pack).
- Three 72-hour actions, each one paragraph, each with verb-first opener + owner role + hour-precise deadline + two citations + one un-closed risk.
- Systemic recommendation is policy / process, not tools / hiring.
- Evidence appendix is exhaustive and traceable.

What "mid-band" (12–18 points) looks like

- Page 1 headline is fluffy ("There appears to have been a security incident...").
- Actions are present but missing one of the required elements (often the "one risk this does not close" piece).
- Systemic recommendation is tool-shaped ("buy a better SIEM").
- Appendix is incomplete — missing files or external references that appeared in the body.

What "low" (0–10 points) looks like

- D3 reads as technical narrative aimed at analyst peers, not executives.
- Actions assigned to personal names instead of roles.
- No deadlines on actions.
- Systemic recommendation is "improve monitoring" or generic.
- Evidence appendix missing.

D3 scoring table

Element	Max	What full credit needs
Page 1 audience test (executive-readable)	5	First sentence is a conclusion; no MITRE IDs in prose
Headline finding clear and honestly qualified	4	States what was compromised and how; names what is not yet known
Page 2 includes one external reference	2	NIST CSF function, MITRE technique by name, or ISO control area
Three 72-hour actions, complete	8	Each: verb-first / owner role / hour-precise / "e 2 citations / un-closed risk
Systemic recommendation is policy or process	4	Cites D2's dismissal-pattern rows
Evidence appendix complete	2	Every cite in the body appears here

Disqualifiers (cap D3 at 8)

If the submission has any of these, the maximum D3 score is 8 regardless of other quality:

- Personal names assigned as owners on the 72-hour actions instead of roles.

- Systemic recommendation is a tool purchase, a hiring ask, or "raise awareness".
- D3 has no appendix at all.

D4 — Operator essay (10 points)

What you are checking

D4 is two short prompts. Neither has a correct answer. Both demand personal judgment. D4 is **the AI-resistant part of the capstone** — its specific design is to be hard for a chatbot to ghostwrite, because both prompts require the intern to refer to their own D1 / D2 work.

Two graders read every D4 independently. If both flag it as generic or untraceable to the intern's own analysis, D4 earns zero, and the AI-use penalty (-20 overall) may also apply, at super-admin discretion.

Part A — The ethics call (5 points)

The intern is given this scenario: their manager tells them to close a ticket about a senior VP's account, because the VP is in board meetings all week and the manager does not want to "spoil his quarter". The intern has to write what they would do.

A strong Part A:

- Names the relevant ISC2 Code of Ethics canon **by name** — not just "the code applies". The four ISC2 canons are:
1. Protect society, the common good, necessary public trust and confidence, and the infrastructure. 2. Act honorably, honestly, justly, responsibly, and legally. 3. Provide diligent and competent service to principals. 4. Advance and protect the profession. Most interns will cite Canon I or II for this prompt. Either is acceptable. Citing Canon IV here is a stretch.
- States concretely what the intern would DO step by step (escalate to whom, how, with what evidence package).
- States what they would NOT do (close the ticket, agree verbally to drop it).
- Demonstrates that the intern understands the trade-off — their career vs. duty of care to Sankofa — rather than just reciting policy.

A weak Part A:

- "I would report it to the appropriate authorities" — no specifics.
- No canon named.
- No discussion of the personal cost.

Part A scoring table

Element	Max	What full credit needs
ISC2 canon named correctly	1	Canon I, II, III, or IV by number AND short paraphrase
Specific actions: what they would DO	2	Step by step in the next 24 hours; who they escalate to, in what order
Specific things they would NOT do	1	At least one concrete refusal
Demonstrates understanding of the trade-off	1	Acknowledges career risk vs. duty

Part B — The scenario (5 points)

The intern is given this scenario: at 04:47 WAT on a Tuesday, the SIEM fires an alert. The Operations Manager (o.adegoke), who is currently offboarding (ticket SD-40901 open, her key has not been revoked yet), just authenticated via publickey from a residential ISP in Lagos. The intern has 30 minutes before shift handover. What do they do?

A strong Part B:

- Names what they investigated **first** and why. The order matters: a strong answer might say "I'd look at her last successful login first to confirm the time gap; then check whether SD-40901 has a planned-revocation date that

has passed; then check whether her phone is registered to that ISP."

- Names who they escalated to, at what point, and what specifically triggered the escalation.
- States what they chose NOT to do, and why. Did they lock her account? Contact her directly? Involve HR? Open a fresh ticket or append to SD-40901?
- Includes a handover note for the next shift.
- References something from their own D1 / D2 work. This is the AI-proof piece: a real intern will cite a row from their own D1 table.

A weak Part B:

- A list of generic actions in no particular order.
- No mention of what they chose NOT to do.
- No handover note.
- Reads like it could have been written by someone who never opened the evidence pack.

Part B scoring table

Element	Max	What full credit needs
Investigation order is explicit and reasoned	1	At least three things in order, with why
Escalation timing named with specific trigger	1	Names what would tip them over
States what they chose NOT to do	1	At least one specific refusal, with reasoning
Handover note included or summarised	1	What they would tell the next shift
References intern's own D1 or D2 work	1	Cites a row, a ticket, a file from their analysis

Hard zero for D4

If the writing reads like it could apply to any cohort, any case, any intern — give zero AND flag for AI review.

Writing quality (10 points)

This is graded across all four deliverables as a single score out of 10.

Band	Points	What it looks like
Excellent	8–10	Clear sentences. Audience appropriate (D3 is executive, D1 is analyst, D2 is procedural, D4 is reflective). No filler. The intern thought before writing.
Acceptable	5–7	Readable but uneven. Either too verbose for D3 or too curt for D2. Some run-on or comma-splice sentences. Repeats itself.
Weak	1–4	Hard to follow. Tense or voice shifts mid-paragraph. Excessive jargon for the audience (technical terms thrown at executives in D3).

Unreadable	0	Cannot grade because the prose is incoherent. Flag for review.
------------	---	--

Do not double-count writing quality with citation discipline. A submission that cites everything correctly but writes badly should still lose points here.

Citation discipline (10 points)

This is also graded across all four deliverables as a single score out of 10.

A "claim" is any factual statement the intern makes about Sankofa, the breach, the threat actor, the SOC process, NIST/MITRE/ISO, the ISC2 Code of Ethics, or any external framework.

A claim is "cited" when it ends with either a specific reference to the evidence pack (auth-log-q2.txt:14, SD-40812, roster:row 47) or a specific external reference (NIST SP 800-53 AC-2, MITRE T1078 Valid Accounts, ISO 27001 A.9.2.6, NDPA 2023 Section 40, ISC2 Canon I).

Band	Points	What it looks like
Excellent	8–10	Every claim cited. Appendix complete and verifiable. Spot-check 2 random citations — both check out.
Acceptable	5–7	Most claims cited but at least three uncited sentences. External citations sometimes paraphrased instead of referenced.
Weak	1–4	Many uncited claims. Appendix missing or incomplete. Spot-check finds fabricated citations.
None	0	No citations OR fabricated citations. Also triggers AI-use review.

How to spot-check a citation

Pick one NIST / MITRE / ISO citation from the submission. Search for it on the official site (NIST: csrc.nist.gov; MITRE ATT&CK: attack.mitre.org; ISO 27001 is paywalled but Annex A controls are well-indexed). If the cited section / technique does not exist, the citation is fabricated. Note it and flag for AI review.

Step-by-step example: grading one submission

To make this concrete, here is how a single grading session goes.

1. You open the intern's Drive folder. Four documents present. Sharing is correct. Good — you can grade.
2. You open the platform. The 75-word executive summary reads: *"Sankofa was compromised in Q2 by an attacker using stolen SSH keys. The Tier-1 analyst who closed the original alert was working alone and missed the pattern. I am recommending dual-signoff on dismissed alerts and quarterly access reviews. Full evidence in the appendix."* — Promising. Plain language. References both the breach and the procedural fix.
3. You open D3. Page 1, first sentence: *"Sankofa Digital was compromised in Q2 2024 by an external actor calling themselves 'The Griot', who used a stolen SSH publickey to access the gateway server on 04 June at 02:07 UTC and returned the following day."* — Audience test passes. Strong opening.
4. You read the rest of D3. Three 72-hour actions, each one paragraph, each with verb-first opener, owner role, deadline, two citations, and the un-closed risk. Systemic recommendation is "Quarterly access review with mandatory revocation within 72 hours of any offboarding" + cites D2 ticket rows. Appendix complete. D3 score: 24/25 (lost one point for slightly verbose page 1).
5. You open D1. Methodology page defines H/M/L confidence with one example each. Table has 10 rows. All four mandatory rows present. Every row has at least two citations. Confidence column varies (six H, three M, one L). Pattern summary page identifies the throughline and names the next investigative step.

D1 score: 23/25 (rows 7 and 8 cite the same two files; could have pulled in roster corroboration).

6. You open D2. Pattern named in first sentence: *"single-analyst dismissal of MEDIUM-and-above auto-tickets as 'resolved-by-reference', without cross-correlation against the prior 7 days of alerts"*. Strong. Four ticket IDs cited including SD-40812. Disposition and notes columns quoted verbatim from the CSV. Tunde's escalation explicitly named as the break-point. Procedural recommendation is concrete.

D2 score: 18/20.

7. You open D4. Part A names ISC2 Canon I, explains step by step what the intern would do (escalate to Amaka Eze directly, document the request in writing, decline to close the ticket), states what they would NOT do (verbally agree to drop it, mark as resolved-by-reference). Part B walks through investigation order, names HR escalation as the trigger if her last successful login does not have a corresponding badge scan, includes a handover note. References D1 row 4 (the a.eze post-offboard row) as the reason they would look at o.adegoke's revocation date first.

D4 score: 9/10.

8. Writing quality: 9/10 (consistently clear; one passive-voice run-on in D3 page 2).
9. Citation discipline: 9/10 (one D1 row only cites one file; otherwise perfect).
10. **Total: 92/100.** No AI flag.
11. Grader note: *"Strong submission. Page 1 of D3 is the standout — would quote it to executives unedited. Weakest part is D2 rows that paraphrase instead of quote; D2 itself is fine but one ticket walkthrough loses verbatim quoting on the second paragraph. Re-read first: D3 page 1."*

You submit. The second grader has no idea you scored 92 until they submit. They land at 88. The platform shows: passed Stage 0.

Procedure (the actual clicks)

1. Open the intern's Drive folder (the URL is in the executiveSummary field on the platform's grading page).
2. Confirm sharing is "Anyone with the link !' Viewer". If it is not, click "Return for resubmission" on the grading page with a one-line note. Do not grade what you cannot read.
3. Read D3 !' D1 !' D2 !' D4 in that order.
4. Open the grading rubric at /admin/grading/STAGE_0/<internCode> and enter scores per section using the scoring tables in this guide.
5. Add a 50–100 word grader note. Required. Format: one strength, one weakness, the row or page you re-read first.
6. Submit. Your score is hidden from the second grader until they also submit.
7. If you flagged AI use: tick the "Flag this submission for suspected AI generation" checkbox at the bottom of the grading form and write at least one specific reason in the box that appears. Do NOT apply the -20 penalty yourself. A super-admin reviews flagged submissions and decides.

Edge cases — what to do when things are weird

- **Late submission.** Graded against the same rubric. Lateness penalty (if any) is applied by the cohort-window admin separately, not by you.
- **Empty section.** That section receives 0 points; the rest of the rubric still applies. The intern can still pass overall if the remaining sections are strong.
- **Wrong file format.** PDF and DOCX are both fine. Google Sheets, plain .txt, or links to external "preview" pages without the underlying document — return for resubmission. Note the issue in the return reason.
- **Citation appendix on a separate page from D3.** Acceptable as long as it is in the same Drive folder as the other deliverables. Score it as part of D3.
- **Intern submitted only the brief PDF or someone else's work.** 0 across the board. Flag for super-admin.
- **You and the other grader differ by more than 12 points.** A super-admin tie-breaks. This is not a sign you were wrong — it just means two reasonable readers saw it differently. Do not change your score.
- **You suspect AI use but you are not sure.** Flag it and write your reasoning. The super-admin will decide. Better to flag and be overruled than to let an AI submission pass unnoticed.
- **The intern asks you for help via email or Slack while you are grading their submission.** Do not respond. Forward to programme staff. Maintaining grader anonymity is part of the integrity of the process.

Glossary — quick definitions

For graders who are new to security terminology. You do not need to be an expert in any of these; just know what the intern is talking about.

- **SSH publickey authentication:** a way to log into a server using a cryptographic key file instead of a password. If the key file is stolen, the attacker logs in as if they were the legitimate user.
- **TOR exit IP:** an internet address belonging to the TOR anonymity network. Real users almost never log into corporate servers from TOR IPs; attackers often do, to hide their location.
- **SIEM:** Security Information and Event Management — the platform that ingests logs from across an organization and raises alerts when something looks suspicious. Tickets like SD-40812 come from a SIEM.
- **Tier-1 analyst:** the first line of human review on SIEM alerts. They triage, decide whether an alert is real, and either escalate (to Tier-2 / senior analysts) or close.
- **Dismissal:** closing a SIEM ticket as a non-event. The ticket history CSV shows the **disposition** (resolved-by-reference, false-positive, etc.) and the **notes** the analyst wrote.
- **Offboarding:** removing an employee's access when they leave. Failing to revoke their SSH keys means the keys are still valid and can be used by anyone who finds them.
- **MITRE ATT&CK:** a public catalogue of attack techniques (each with an ID like T1078). Interns may cite techniques by name (e.g., "Valid Accounts") or ID.
- **NIST CSF:** the National Institute of Standards and Technology's Cybersecurity Framework. Used in D3 as a vocabulary for risk and recommendations.
- **ISC2 Code of Ethics:** the professional code for security practitioners. Four canons. Cited in D4 Part A.
- **NDPA:** Nigeria Data Protection Act 2023. Relevant when the intern discusses what Sankofa must report.

— UBI Programme Team